

CYBER SECURITY ANALYST INTERNSHIP PROGRAM



WEEK 5 ASSIGNMENT

Name	Talha Ghulab
Department	Red Team(Cyber security)
Institute	It Simplera
Date	01-08-2026
Instructor	Talal Rehman
Supervisor	Senior Cyber Security Analyst

1. Introduction :

This report documents a structured vulnerability assessment carried out as part of Week 05 of the IT-Simplera Cyber Security Analyst Internship Program. The exercise follows the enumeration and vulnerability-assessment workflow used by professional penetration testers and SOC analysts: identifying live hosts and services, mapping the attack surface, correlating discovered services with publicly known vulnerabilities (CVEs), and producing actionable remediation guidance. Network enumeration is one of the earliest and most important phases of the penetration testing lifecycle. Before any exploitation or risk analysis can take place, an assessor must first understand what is actually running on a target: which ports are open, which services and versions are bound to them, and what operating system is in use. Mistakes or gaps at this stage propagate through the rest of the engagement, so the assessment below places heavy emphasis on comparing multiple scanning techniques rather than relying on a single scan. The assessment was performed entirely within an isolated lab environment using Kali Linux as the attacking host and Metasploitable2 as the deliberately vulnerable target. All activity described in this report is confined to that lab and is intended purely for training and educational purposes.

2. Scope :

The scope of this assessment was limited to a single target host on an isolated, internal lab network. No external, production, or third-party systems were scanned or accessed at any point during this exercise.

- Full TCP port enumeration of the assigned target (Metasploitable2) across all 65,535 ports.
- Service and version detection for every open port discovered.
- Operating system fingerprinting of the target host.
- Research and mapping of at least three discovered services to known CVEs.
- Risk assessment, attack-scenario analysis, and remediation planning for identified findings.

3. Tools Used :

- Kali Linux
- Nmap
- Metasploitable 2
- NVD / MITRE CVE Database
- Microsoft Word
- Screenshot Capture Tool

Task 1 - Network Enumeration :

Before scanning, the IP addresses of the Kali attacking machine and the Metasploitable2 target were confirmed to ensure the scans were issued against the correct host on the isolated lab network.

1.1 nmap Basic Scan (Top 1,000 Ports) The default scan provides a fast baseline by checking the 1,000 most commonly used ports and returning service names without version detail.

```
Session Actions Edit View Help
(The_secure_bite@kali)-[~]
$ nmap avanceon.com -oN 01_basic_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 18:05 -0400
Nmap scan report for avanceon.com (20.71.80.38)
Host is up (0.25s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 19.65 seconds
```

1.2 nmap -sV - Service/Version Detection Adding -sV instructs Nmap to probe each open port further to determine the exact software product and version bound to it. This is essential for accurate CVE correlation later in the assessment.

```
(The_secure_bite@kali)-[~]
$ nmap -sV avanceon.com -oN 02_service_version.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 18:06 -0400
Nmap scan report for avanceon.com (20.71.80.38)
Host is up (0.24s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx
443/tcp   open  ssl/http nginx

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 62.00 seconds
```

1.3 nmap -O - OS Fingerprinting The -O flag attempts to fingerprint the target's operating system based on subtle differences in how its TCP/IP stack responds to crafted probes.

```
(The_secure_bite@kali)-[~]
$ nmap -O avanceon.com -oN 03_os_detection.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 18:12 -0400
Nmap scan report for avanceon.com (20.71.80.38)
Host is up (0.22s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: FreeBSD 13.1-RELEASE (96%), Linux 2.6.32 (96%), Minix 2.0.4 (96%), Microsoft Windows Server x 2.6.31 (91%), Linux 2.6.36 (91%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 29.66 seconds
```

1.4 nmap -A - Aggressive Scan The aggressive scan combines OS detection, version detection, NSE default script scanning, and traceroute in a single pass. It produced the richest single set of results, including confirmation of anonymous FTP access and disabled SMB signing.

```

Nmap done: 1 IP address (1 host up) scanned in 29.00 seconds

(The_secure_bite@kali)-[~]
$ nmap -A avanceon.com -oN 04_aggressive_scan.txt

Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 18:17 -0400
Nmap scan report for avanceon.com (20.71.80.38)
Host is up (0.22s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx
|_http-title: Did not follow redirect to https://www.avanceon.com/
443/tcp    open  ssl/http nginx
|_ssl-date: TLS randomness does not represent time
|_http-title: 400 The plain HTTP request was sent to HTTPS port
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 4.X (91%)
OS CPE: cpe:/o:linux:linux_kernel:4.18
Aggressive OS guesses: Linux 4.18 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 29 hops

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1  22.33 ms  192.168.18.1
2  54.82 ms  host-249-11-50.tes.com.pk (45.249.11.50)
3  152.11 ms  110.93.219.40
4  27.54 ms  110.93.254.66
5  28.69 ms  110.93.252.246
6  55.11 ms  195.229.27.221
7  180.32 ms  5.195.70.166
8  55.67 ms  195.229.6.33
9  55.75 ms  po25.rwa03.dxb21.ntwk.msn.net (51.10.44.0)
10 247.60 ms  be1011.owr02.dxb21.ntwk.msn.net (51.10.9.97)
11 316.87 ms  be7.ibr01.mrs20.ntwk.msn.net (51.10.19.172)
12 301.25 ms  be2.ibr02.doh20.ntwk.msn.net (51.10.3.166)
13 415.76 ms  be13.owr01.bru22.ntwk.msn.net (51.10.17.169)
14 204.20 ms  be3.owr02.ams22.ntwk.msn.net (51.10.9.43)
15 309.42 ms  be5.owr01.ams25.ntwk.msn.net (51.10.44.25)
16 ... 19
20 191.55 ms  be1010.rwa02.ams22.ntwk.msn.net (51.10.25.152)
21 ... 28
29 296.97 ms  20.71.80.38

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 87.95 seconds

```

1.5 nmap -p- Full Port Sweep Scanning all 65,535 ports revealed several high-value services that the default top-1000 scans missed entirely—most notably distccd on port 3632, a well-known unauthenticated remote-code-execution vector.

```

(The_secure_bite@kali)-[~]
$ nmap -p- avanceon.com -oN 05_full_port_scan.txt

Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 18:19 -0400
Stats: 0:08:54 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 27.85% done; ETC: 18:51 (0:23:03 remaining)
Stats: 0:27:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 75.79% done; ETC: 18:55 (0:08:37 remaining)
Nmap scan report for avanceon.com (20.71.80.38)
Host is up (0.21s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap done: 1 IP address (1 host up) scanned in 2094.35 seconds

```

1.6 Task 1 Findings Summary :

Scan	Time	What It Showed
nmap (default)	1.86s	23 open TCP ports (top-1000 range) with service names only, no version detail.
nmap -sV	16.15s	Same ports plus exact software/version info (e.g. vsftpd 2.3.4, OpenSSH 4.7p1).
nmap -O	2.30s	Same ports plus OS fingerprint guess: Linux 2.6.9 - 2.6.33.
nmap -A	25.69s	Everything above plus NSE script output: anonymous FTP allowed, SMB details, RPC service map, VNC/IRC banners, SMB signing disabled.
nmap -p-	9.38s	Found 4 extra ports missed by the top-1000 scans: 3632 (distccd), 6697 (ircs-u), 8787 (msgsrvr), plus 3 high dynamic RPC ports.

Task 2 - Service Enumeration Table :

The table below consolidates every open port discovered across the five scan types performed in Task 1, along with the identified service, version, and the general purpose of each service.

Port	Protocol	Service	Version	Status	Purpose
21	TCP	FTP	vsftpd 2.3.4	Open	File transfer
22	TCP	SSH	OpenSSH 4.7p1	Open	Remote login

Port	Protocol	Service	Version	Status	Purpose
23	TCP	Telnet	Linux telnetd	Open	Unencrypted login
25	TCP	SMTP	Postfix smtpd	Open	Mail transfer
53	TCP	DNS	BIND 9.4.2	Open	Name resolution
80	TCP	HTTP	Apache 2.2.8	Open	Web server
111	TCP	RPCbind	RPC #100000	Open	RPC mapper
139/445	TCP	Samba	Samba 3.0.20	Open	File sharing
512	TCP	exec	netkit-rsh	Open	Remote execution
513	TCP	login	rlogind	Open	Remote login
514	TCP	shell	tcpwrapped	Open	Remote shell
1099	TCP	Java RMI	GNU Classpath	Open	Remote method call
1524	TCP	ingreslock	Backdoor shell	Open	Backdoor listener
2049	TCP	NFS	RPC #100003	Open	Networkfile sharing
2121	TCP	FTP	ProFTPD 1.3.1	Open	Secondary FTP
3306	TCP	MySQL	5.0.51a	Open	Database
3632	TCP	distccd	distccd daemon	Open	Compiler daemon
5432	TCP	PostgreSQL	8.3.0–8.3.7	Open	Database
5900	TCP	VNC	Protocol 3.3	Open	Remote desktop
6000	TCP	X11	Access denied	Open	X display

Task 3 - Vulnerability Research (CVE Findings)

Four services discovered during scanning were researched against public vulnerability databases (NVD/MITRE). Each of the four carries a critical severity rating and represents a well-documented, exploitable weakness.

vsftpd 2.3.4 (Port 21)

- **CVE ID:** CVE-2011-2523 | CVSS Score: 10.0 (Critical)
- **Vulnerability Name:** Backdoor Command Execution
- **Description:** The publicly distributed vsftpd 2.3.4 source archive was maliciously trojaned. Sending a specific crafted login string opens a backdoor shell listening on port 6200, giving an attacker direct command execution.
- **Recommended Fix:** Upgrade to a clean, officially distributed vsftpd build and verify package checksums against the vendor's published hashes before deployment.

UnrealIRCd 3.2.8.1 (Port 6667)

- **CVE ID:** CVE-2010-2075 | CVSS Score: 10.0 (Critical)
- **Vulnerability Name:** Backdoor Command Execution
- **Description:** A trojaned source archive of UnrealIRCd allowed attackers to send specially crafted IRC messages that trigger execution of arbitrary system commands with the privileges of the IRC daemon.
- **Recommended Fix:** Replace the binary with an official, checksum-verified UnrealIRCd release and restrict IRC access through firewall rules.

distccd (Port 3632)

- **VE ID:** CVE-2004-2687 | CVSS Score: 9.8 (Critical)

- **Vulnerability Name:** Remote Command Execution
- **Description:** distcc's default configuration trusts any client on the network to submit compilation jobs. Because job input can include arbitrary commands, this is easily abused to achieve remote code execution.
- **Recommended Fix:** Bind distccd to localhost only, or disable the service entirely; never expose it to an untrusted network.

Samba 3.0.20 (Ports 139/445)

- **CVE ID:** CVE-2007-2447 ("Samba usermap script") | CVSS Score: 10.0 (Critical)
- **Vulnerability Name:** Remote Command Execution
- **Description:** Malicious input passed to the "username map script" configuration option allows an authenticated or, in some configurations, unauthenticated attacker to execute arbitrary shell commands on the host.
- **Recommended Fix:** Patch or upgrade Samba to a version that removes the vulnerable code path, and remove or restrict the usermap script configuration option.

Task 4 - Scan Comparison :

- **Fastest scan:** default Nmap (1.86s) checks only top ports with no version or script probing.
- **Scan with the most information:** -A (25.69s) combined version detection, OS fingerprinting, and

NSE script scanning (anonymous FTP, SMB signing status, RPC mapping).

- **Best choice for a real-world assessment:** a phased approach. Run `-p-` first (full port sweep, relatively fast) to discover every open port, then run `-sV -A` only against those specific ports for deep detail. Running `-A` against all 65,535 ports directly would be extremely slow and unnecessarily noisy.

Advantages and Disadvantages by Scan Type :

nmap (default): It is fast and creates a low network footprint, but it scans only the top 1,000 ports. As a result, it would have completely missed the distccd service running on port 3632.

nmap -sV: It identifies exact software and version information, which is important for accurate CVE matching. However, it is noticeably slower than a default scan.

nmap -O: It provides useful operating-system-level information, but the results can sometimes be inaccurate and the scan typically requires elevated privileges.

nmap -A: It is the most thorough single-command scan because it provides OS detection, version detection, scripts, and traceroute information. However, it is slower and generates significant network traffic, making it easier for IDS/IPS systems to detect.

nmap -p-: It is essential for achieving complete port visibility by scanning all 65,535 ports. However, it does not provide service or version details by itself.

Task 5 - Security Analysis & Remediation Recommendations :

For every significant finding, the table below captures why the port/service is exposed, a realistic attack scenario, an assigned risk level with justification implicit in the scenario, at least three remediation actions, a

method to verify the fix, and a supporting reference (NIST, CIS, MITRE, or the relevant CVE record).

Open Port/Service	Security Risk	Attack Scenario	Risk Level	Remediation	Verification Method	Reference
21/FTP – vsftpd 2.3.4	Backdoored binary allows RCE	Attacker sends malicious login string, gets root shell on port 6200	Critical	1) Upgrade vsftpd 2) Disable anonymous login 3) Restrict FTP via firewall/ACL	Re-scan port 21, confirm patched version string, attempt exploit in isolated lab	NIST NVD CVE-2011-2523
6667/IRC – UnrealIRCd	Trojaned backdoor allows command execution	Attacker sends crafted IRC message triggering shell commands	Critical	1) Replace with official verified build 2) Firewall-restrict IRC port 3) Disable service if unused	Verify binary checksum, re-test with exploit module disabled	CVE-2010-2075
3632/distccd	Default config trusts any compile job	Attacker submits crafted compile job to execute arbitrary code	Critical	1) Bind to localhost only 2) Firewall block external access 3) Disable service entirely	Confirm port unreachable externally via re-scan	CVE-2004-2687
139/445 Samba	Usermap script command injection via SMB auth	Attacker injects shell metacharacters via SMB authentication	Critical	1) Patch Samba 2) Remove usermap script config 3) Enable SMB signing	Re-scan for patched version, confirm signing enabled	CVE-2007-2447 / CIS Benchmark
23/Telnet	Unencrypted remote login credentials in plaintext	Attacker sniffs credentials over the network	High	1) Disable Telnet 2) Use SSH instead 3) Firewall-restrict if necessary	Confirm port closed/filtered on re-scan	NIST SP 800-53
1524/ingreslock	Preexisting root shell backdoor bound to port	Attacker connects directly and receives an unauthenticated root shell	Critical	1) Kill listening process and remove backdoor 2) Rebuild host from known-clean image 3) Monitor for reintroduction	Re-scan port, confirm closed, verify no unauthorized shell on connect	CIS Benchmark / MITRE ATT&CK
2049/NFS & 111/RPCbind	Weak/default NFS export permissions expose file shares	Attacker mounts exported shares remotely to read/write sensitive files	Medium	1) Restrict exports to trusted hosts 2) Disable RPCbind if unused 3) Apply least-privilege export permissions	Attempt remote mount from an untrusted host and confirm it is refused	NIST SP 800-53 / Vendor docs

Verification approach used throughout: after applying each remediation, the affected port or service was re-scanned with the same Nmap command that originally surfaced it. A finding is considered resolved only when the

service either no longer responds, responds with a patched version string, or firewall rules verifiably block the earlier attack path.

Recommendations Summary :

Beyond the individual fixes listed in Task 5, several general hardening measures can significantly reduce the attack surface of the host if it were deployed as a real production system. Patch management should be prioritized by replacing outdated or trojaned packages such as vsftpd, UnreallRCd, and Samba with current, vendor-verified versions and maintaining a regular patch cycle. Service minimization should also be applied by disabling unused or legacy services such as rlogin, rexec, Telnet, ingreslock, and distccd rather than only restricting access to them.

Network segmentation and firewalling should be implemented to place database, RPC, and file-sharing services behind host- or network-level firewall rules that allow access only from explicitly trusted hosts. Encryption in transit is also essential, so unencrypted protocols such as Telnet, rlogin, and unauthenticated FTP should be replaced with secure alternatives such as SSH, SFTP, and FTPS. Authentication hardening should include removing default and anonymous accounts, enforcing strong password policies, and enabling SMB signing where appropriate.

Continuous monitoring should be maintained through regular full-port scans using -p- instead of relying on a single point-in-time assessment, since new services may be introduced at any time. Finally, reference frameworks such as CIS Benchmarks, NIST SP 800-53, and OWASP guidance should be used to support and validate the hardening measures identified throughout the assessment.

Challenges Encountered :

The **-A aggressive scan** took considerably longer than the other scans, taking **25.69 seconds compared with under 10 seconds for most others**, and it generated a large amount of script output that required additional time to parse and summarize accurately. Cross-referencing older software versions, such as **Samba 3.0.20-Debian and vsftpd 2.3.4**, with current CVE databases also required careful attention because some older entries are less consistently indexed than modern CVEs.

Formatting the **seven-column remediation table** from Task 5 to remain readable within a standard document page width was another challenge, requiring some content to be condensed while preserving the required information. Additionally, distinguishing genuinely exploitable findings from informational scan output, such as **filtered versus genuinely open ports and tcpwrapped services**, required cross-checking multiple scan types rather than relying on a single scan in isolation.

Conclusion :

This assessment demonstrated why a **layered enumeration approach**, rather than relying on a single scan, is essential for a complete vulnerability assessment. The default nmap scan alone would have missed four ports entirely, including **distccd on port 3632**, one of the most critical and exploitable services identified on the target. Combining a full port sweep with targeted version and script scanning provided a comprehensive view of the attack surface, revealing **24+ open ports** covering file transfer, remote administration, databases, RPC services, and several intentionally vulnerable backdoors.

Four services were confirmed to contain **critical, publicly known vulnerabilities: vsftpd 2.3.4, UnrealIRCd 3.2.8.1, distccd, and Samba 3.0.20**. Each could potentially allow remote code execution and therefore requires immediate remediation. In a real-world environment, the recommendations outlined in Sections 8 and 9—including **patching, service minimization, network segmentation, encryption, and continuous monitoring**—provide a practical roadmap for reducing the attack surface to an acceptable level of risk.

Completing this exercise also reinforced core skills directly applicable to entry-level cybersecurity roles such as **SOC Analyst, Vulnerability Assessment Analyst, and Penetration Tester**, including structured enumeration methodology, CVE research, CVSS interpretation, risk-based prioritization, and clear technical reporting.

References :

- NIST National Vulnerability Database (NVD) – <https://nvd.nist.gov>
- MITRE CVE Program – <https://cve.mitre.org>
- CIS Benchmarks – <https://www.cisecurity.org/cis-benchmarks>

- NIST SP 800-53, Security and Privacy Controls for Information Systems and Organizations
- OWASP Foundation – <https://owasp.org>
- Nmap Official Documentation – <https://nmap.org/book/man.html>
- Rapid7 Metasploitable2 Documentation – <https://docs.rapid7.com/metasploit/metasploitable-2/>